

master IW informatica

Gebruiksvriendelijke beveiligingsmodellerings tool voor de fortunately-unfortunately methode

Juryverdediging februari 2026

Mika Gielkens

Promotoren: Prof. dr. ir. Koen Yskout, dr. Eva Geurt

KULeuven/UHasselt

Inhoudsopgave

Situering en doel

Situering

- Threat modeling
 - Vaak:
 - Uitgesteld
 - Oppervlakkig
 - Overgeslagen
 - Redenen:
 - Tijdsdruk
 - Beperkte securityexpertise
 - Beperkte passende tooling
 - Bestaande methoden:
 - STRIDE
 - Attack trees
- Problemen met methoden:
 - Nodige kennis
 - Formele notaties
 - Kennis standaarddreigingen
 - Beperkte domeinspecifieke tools

Doel van de thesis

- Adhv fortunately-unfortunately methode
- Kloof verkleinen
- Gebruiksvriendelijke webtool
- Efficiëntie
- Toegankelijk voor niet-security experts

Onderzoeksvragen

1. Welke basisfunctionaliteit is minimaal noodzakelijk om threat modeling met fortunately-unfortunately trees te ondersteunen?
2. Welke extra functies (bv. filters, zoekfuncties, statusiconen en visuele structuren) worden door gebruikers als het meest nuttig ervaren?
3. Hoe verhoudt de voorgestelde tool zich qua gebruiksvriendelijkheid en effectiviteit ten opzichte van een basisversie van mindmapsoftware?

Fortunately-unfortunately methode

Fortunately-unfortunately methode

- Afkomstig uit theater
- Gebruikt als thread-modelingtechniek
- Afwisseling gunstig en ongunstig

Werking van de methode

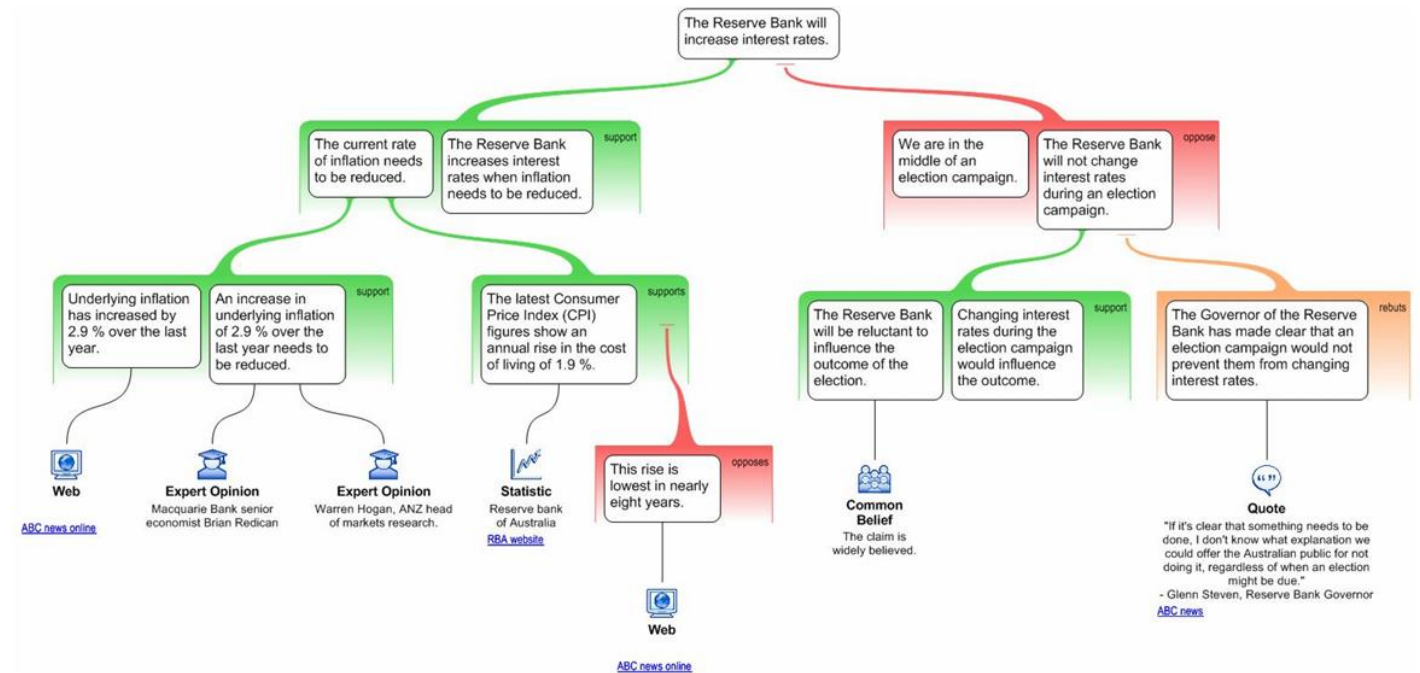
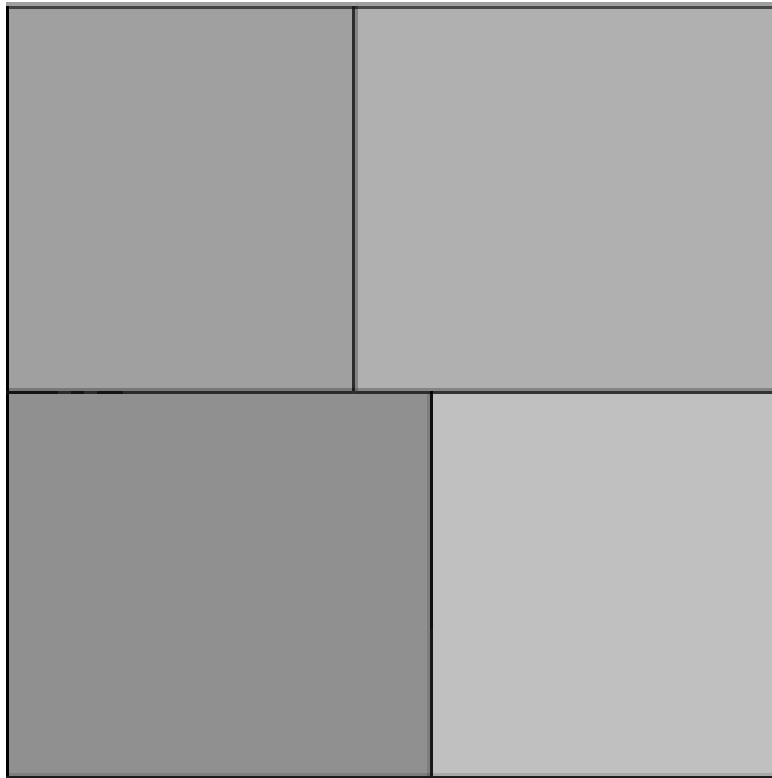
- Begin met fortunately
- Hierna unfortunately
- Verdere afwisseling doorheen tree
- Voorbeeld branch:
 - Fortunately: "Uitrol wachtwoordmanager verbetert gebruiksgemak"
 - Unfortunately: "Werknemers weigeren wachtwoordmanagers;
 - Fortunately: "Training verlaagt drempel".

Gerelateerd werk

Gerelateerd werk

- Geen bestaande tools
- Focus op STRIDE, attack trees, ...
- Mogelijkheid gebruik generieke mindmapsoftware
- Visualisatie technieken
 - Treemaps
 - Circulaire treemaps
 - Argument-mappingtool (hi-tree)
 - Duidelijkere relatie

Visualisatie technieken



Ontwerp van de tool

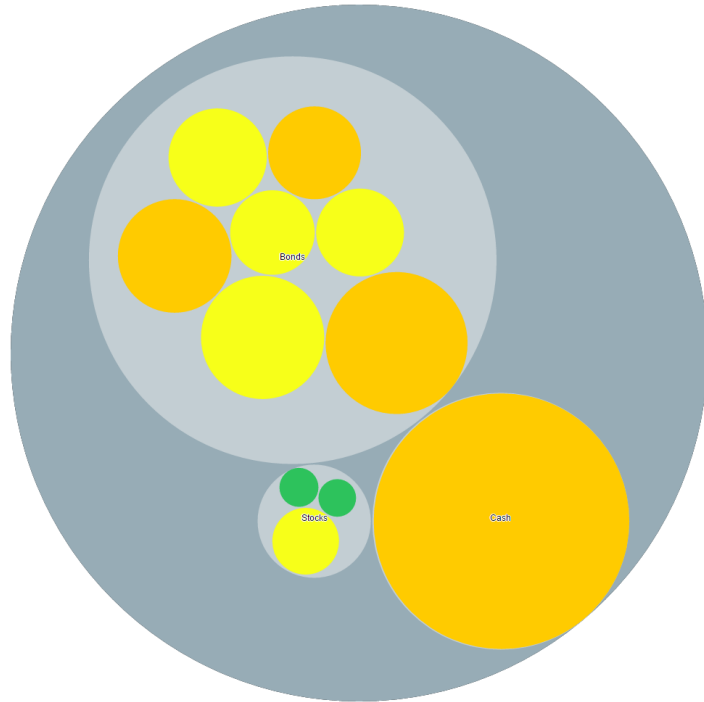
De basis van de tool

- Single-page webapplicatie
- React
- Next.js
- D3 library
- Node opbouw:
 - Children
 - Danger rating
 - Level
 - Status

Visualisatie

- Onderzocht:

- Treemaps
- Circulaire treemaps



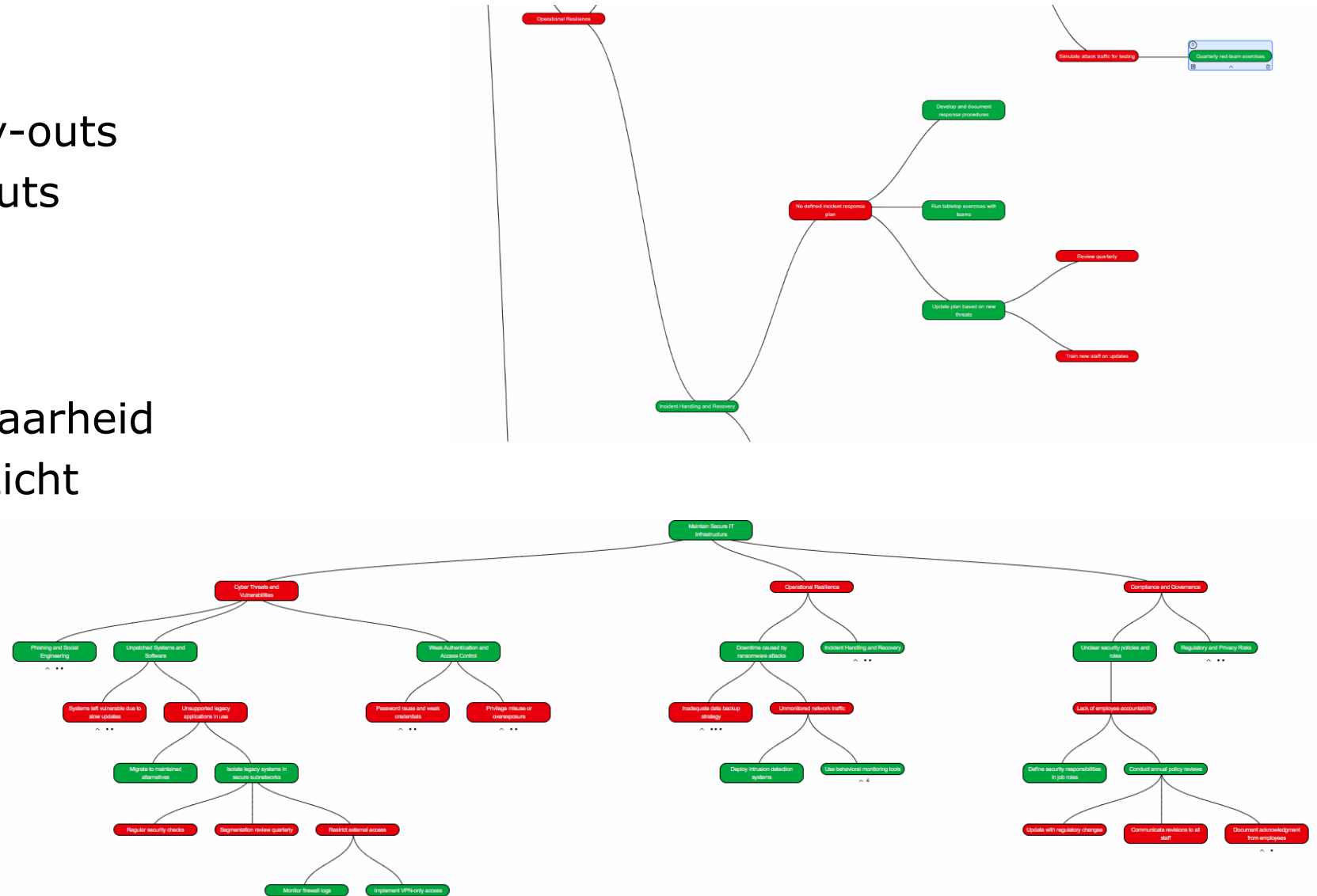
- Structuur:

- Goed ruimtegebruik
- Onduidelijke sequentiële weergave
- Onduidelijk parent-child relatie



Visualisatie

- Geïmplementeerd:
 - Horizontale tree lay-outs
 - Verticale tree lay-outs
- Structuur:
 - Onvoldoende leesbaarheid
 - Onvoldoende overzicht
 - Teveel witruimte



Gekozen visualisatie

- Ontwikkelde implementatie:
 - Fileview-geïnspireerde lay-out
- Structuur:
 - Compact
 - Hiërarchische bestandweergave
 - Bekend voor IT
 - Duidelijke lineaire volgorde
 - Optimaal schermgebruik



Basisfuncties van de tool

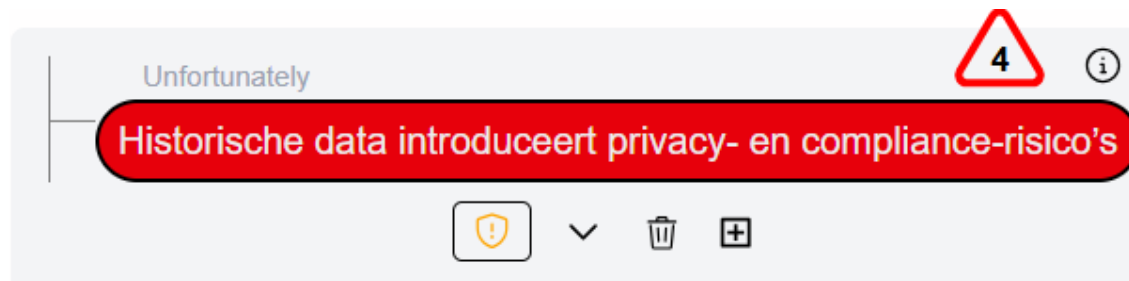
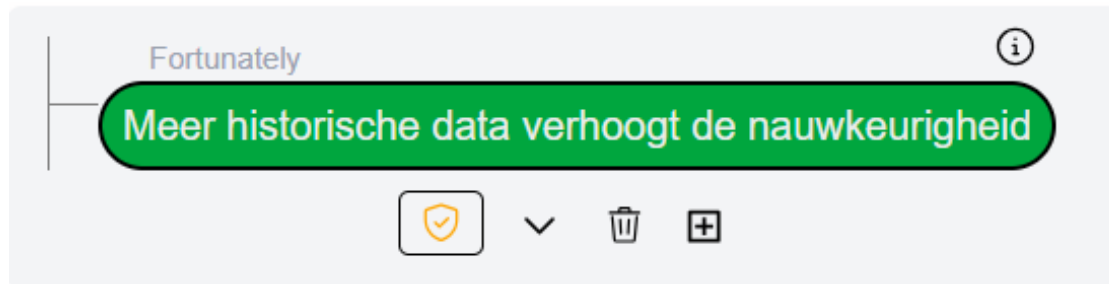
- Nodes aanmaken
- Nodes hernoemen
- Uit- en inklappen van branches
- Eenvoudige zoekfunctie

Toegevoegde features

- Focus op:
 - Gebruiksgemak
 - Efficiëntie
- Features:
 - Duidelijke node visualisatie
 - Statusiconen
 - Danger rating
 - Branch summary
 - Filterlogica

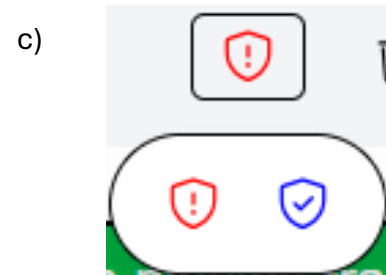
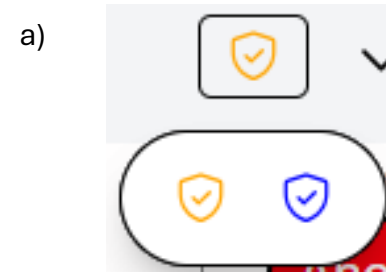
Node visualisatie

- Fortunately -> Groen
- Unfortunately -> Rood
- Consistente vormgeving



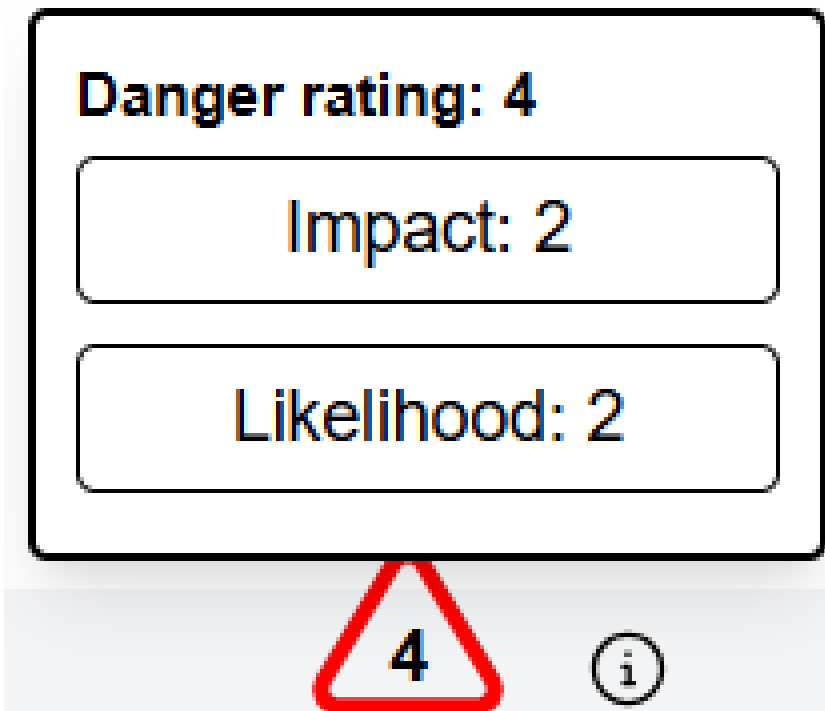
Statusiconen

- Statussen:
 - Weakness
 - Weakness Under Review
 - Assumption Under Review
 - Verified Assumption
- Schild-icoon weergave
 - Associatie beveiliging
- Context afhankelijke selectie



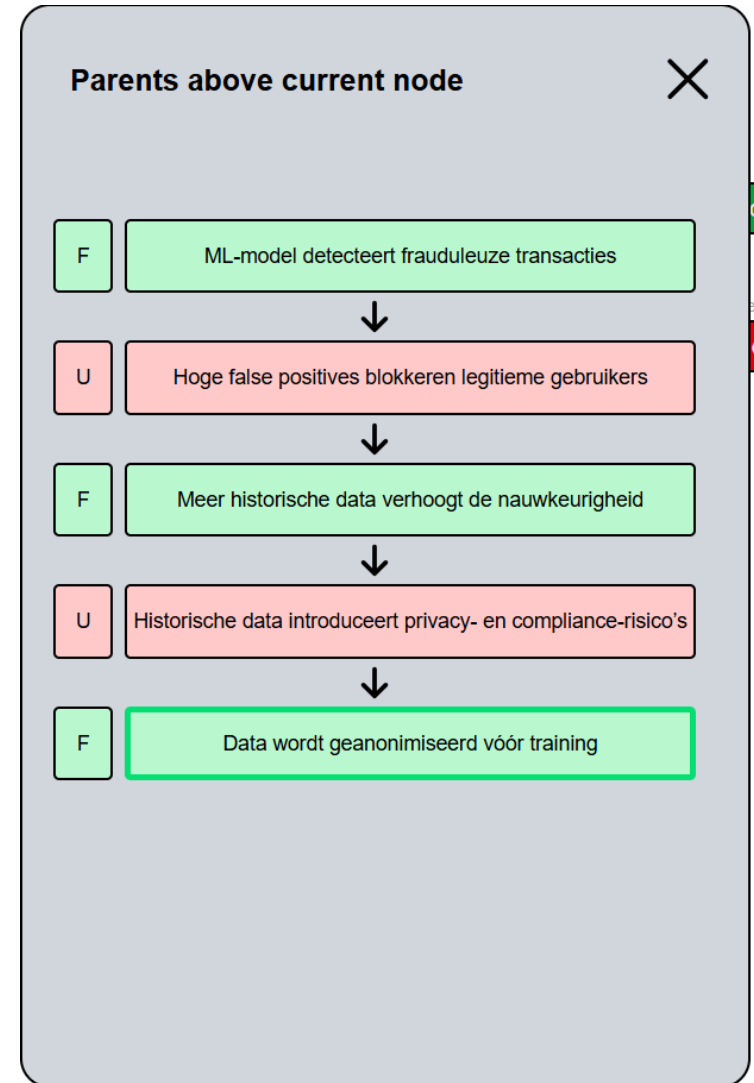
Danger rating

- Kwantitatieve risico inschatting
- Adhv impact en likelihood
 - Waarde van 1-5
- Waarschuwingdriehoek-icoon
 - Gevaaraanduiding dagelijks leven
 - Intuïtieve interpretatie
- Constant zichtbaar
- Bij weaknesses (under review)



Branch summary

- Globale context
 - Verhoging overzicht
- Zijpaneel
- Reconstructie:
 - Root -> geselecteerde node
- Ondersteuning taken als:
 - Samenvatten
 - Controleren keten



Filter logica

- Filter op status
- Werklijst
- Prioritering
- Ingeklapt:
 - Aantal nodes per status
 - Compacte schild-knop
 - Overzicht globale voortgang



Filter logica

- Uitgeklapt:
 - Gegroepeerd per status
 - Sortering op danger rating
 - Kritieke weakness bovenaan

The screenshot shows a modal window titled 'Unfortun...' with a close button. It contains four filter buttons: 'Weaknesses' (red warning icon), 'Weaknesses Under Review' (yellow warning icon), 'Assumptions Under Review' (yellow warning icon), and 'Verified assumptions' (green checkmark icon). Below the filters is a list of weaknesses, each with a danger rating icon (triangle with exclamation mark), a status icon (U for Under Review), and a description. The list is sorted by danger rating in descending order. The first item has a rating of 20 and the last has a rating of 6. A 'Danger Rating' label with a downward arrow is visible on the left side of the list.

Danger Rating	Status	Description
20	U	Driftalarmen veroorzaken alert-moeheid bij engineers
18	U	Junior Teamleden interpreteren beslissingen op hun eigen manier
18	U	Continue retraining kan compliance regels overtreden (bijv. GDPR, bias)
15	U	Onjuiste of verouderde trainingsdata beïnvloedt modelprestaties
12	U	Fouten in preprocessing kunnen bias in model introduceren
10	U	Anonimisatie vermindert detail in features en verlaagt prestaties
8	U	Engineers negeren lage-prioriteitsmeldingen die soms kritiek blijken
6	U	Audits verhogen administratieve overhead

- Bij klik:
 - Naar node in tree
 - Highlighting

The screenshot shows a modal window titled 'fortu...' with a close button. It contains four filter buttons: 'Weaknesses' (red warning icon), 'Weaknesses Under Review' (yellow warning icon), 'Assumptions Under Review' (yellow warning icon), and 'Verified assumptions' (green checkmark icon). Below the filters is a list of verified assumptions, each with a status icon (F for Verified) and a description. The list is sorted by status in ascending order. The first item has a status of F and the last has a status of F. A 'Verified assumptions' label with an upward arrow is visible on the left side of the list.

Status	Description
F	ML-model detecteert frauduleuze transacties
F	Meer historische data verhoogt de nauwkeurigheid
F	Data wordt geanonimiseerd vóór training
F	Feature engineering verbetert prestaties op een veilige manier
F	Realtime waarschuwingen voorkomen financiële schade
F	Systeem optimaliseert door laag-risico transacties te batchen
F	Hardware wordt opgeschaald tijdens piekmomenten
F	Team voert uitlegbaarheidstools toe om modelbeslissingen te verduidelijken

Prototype beperkingen

- Lokale opslag
- Geen multi-user synchronisatie
- Geen performance optimalisatie

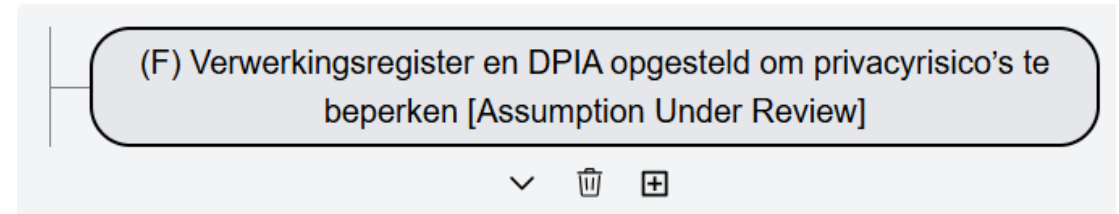
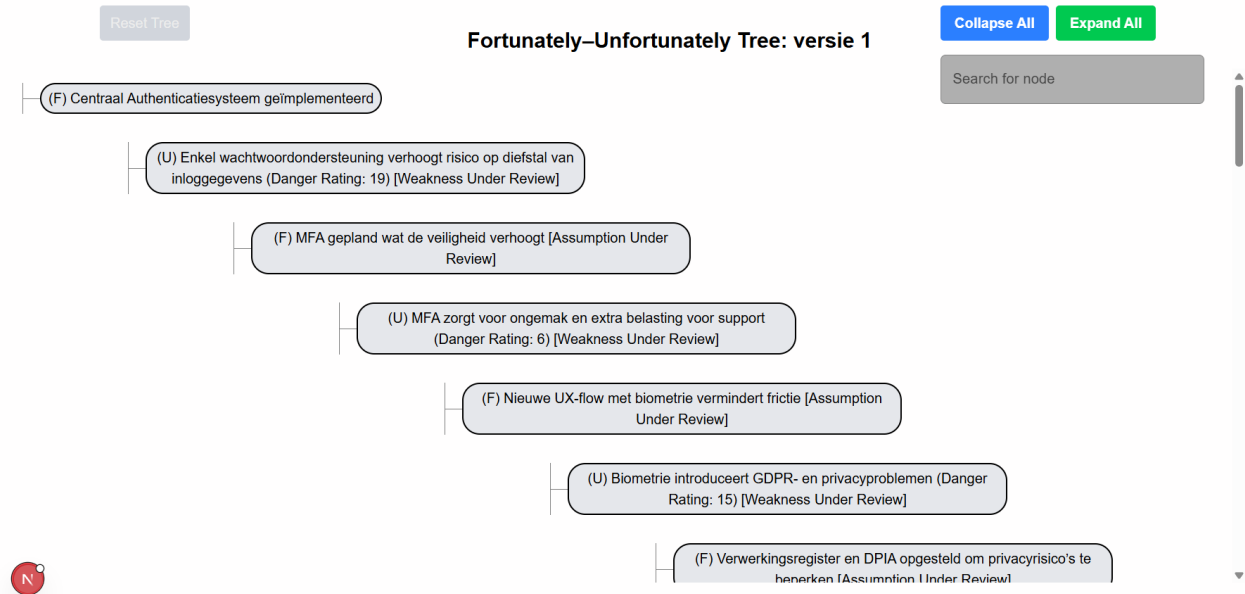
Gebruikersstudie

Gebruikersstudie

- Negen deelnemers
 - 20-28 jaar
 - Achtergrond in informatica
 - Zeven geen security-modellering-ervaring
 - Studenten, junior developers, data engineer, scrum master
- Twee scenario's
 - Inlog- en authenticatiesysteem
 - AI-fraudedetectiesysteem
- Taken:
 - Nodes toevoegen
 - Statussen toekennen
 - Opsommingstaken
 - Reconstructie van keten

Gebruikersstudie

- Twee versies van software:
 - Basisversie
 - Uitgebreide versie
- Basisversie -> scenario 1
- Uitgebreide versie -> scenario 2



Dataverzameling

- Opname scherm
- Live opgevolgd
- User Experience Questionnaire (UEQ)
- Vragen/rangschikking

Beperkingen gebruikersstudie

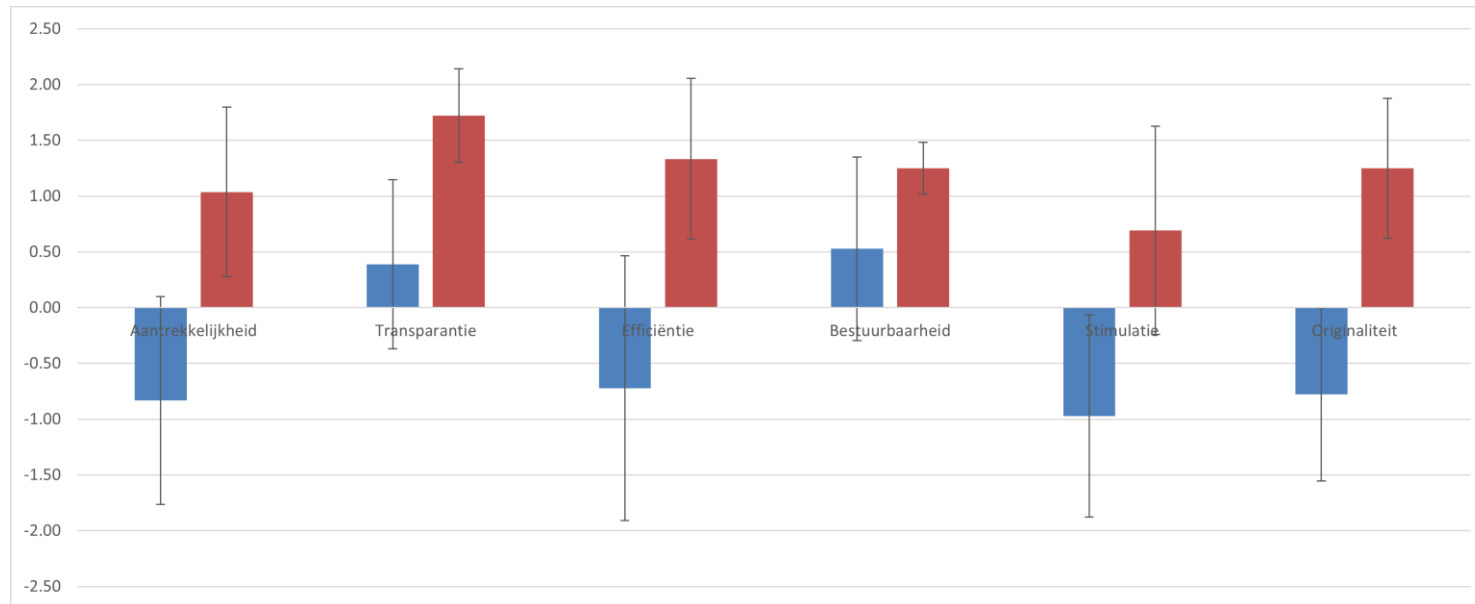
Beperkingen gebruikersstudie

- Kleine steekproef/populatie
 - Bewust deelnemers informatica achtergrond
 - Realistische simulatie
 - Ontbreken van security-experts
- Zelfrapportage/bias
 - Subjectiviteit
 - Confirmation bias
 - Variatie in geteste versie volgorde
- Beperkte vergelijkingsbasis en duur
 - Vergelijking met basisversie
 - Gecontroleerd referentiepunt
 - Korte eenmalige taken

Resultaten

Resultaten

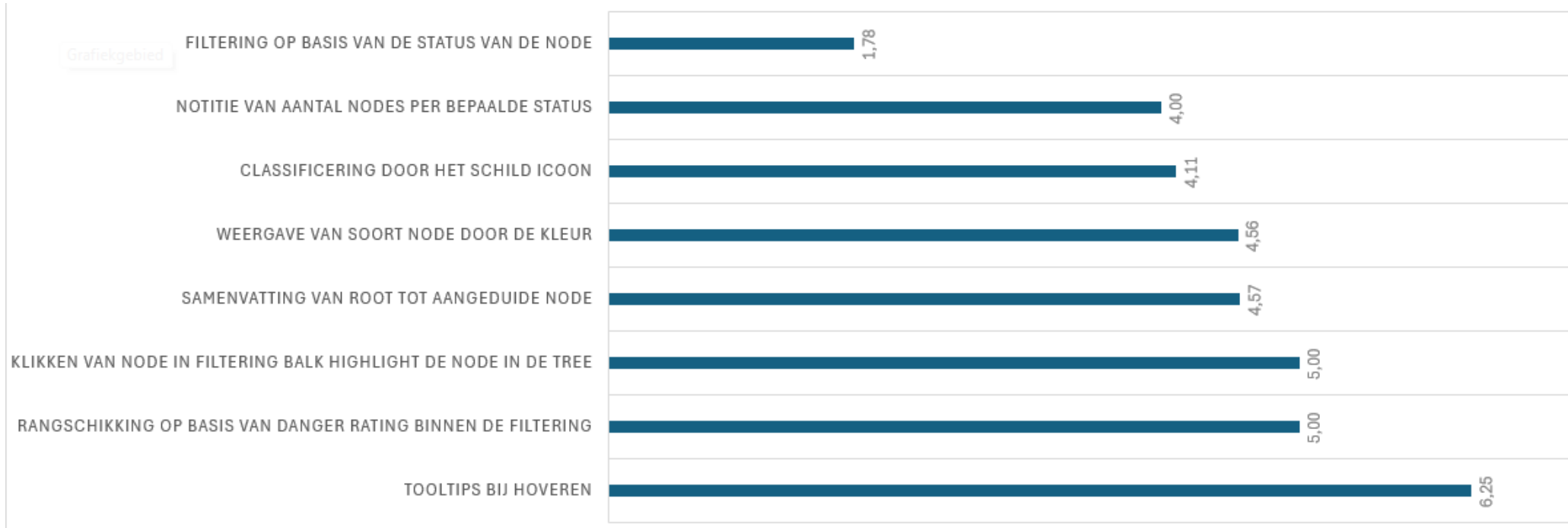
- UEQ (laagste -3, hoogste +3):
 - Aantrekkelijkheid: -0,83 ➡ 1,04
 - Efficiëntie: -0,72 ➡ 1,72
 - Stimulatie: -0,97 ➡ 1,33
 - Originaliteit: -0,78 ➡ 1,25
 - Transparantie: -0,39 ➡ 0,69
 - Bestuurbaarheid: 0,53 ➡ 1,25



Observaties

- Basisversie:
 - Veel scrollen en zoeken
 - Zoekbalk-afhankelijkheid
 - Handmatig tellen
 - Danger rating/status vergeten
 - Manuele kettingreconstructie
- Problemen:
 - Te veel tijd
 - Foutgevoelig
 - typefouten
- Uitgebreide versie oplossingen:
 - Standaard status
 - Visueel prominente danger rating
 - Directe filtering
 - Branch Summary ipv manueel
 - Sneller en minder foutgevoelig

Ranking van features



Branch summary door twee deelnemers niet gevonden

Verbeterpunten

- Compactere weergave tree
- Intuïtiever manier van in en uit klappen
- Duidelijkere indicatie geactiveerde collapse/expand-knop
- Eenvoudigere manier annuleren van aangemaakte node
- Meer context bij searchbar
- Aanpassing van sortering danger rating
- Aantal per status ook in uitgeklapte weergave

Mogelijke toevoegingen

- Custom statussen
- Inzoomen op een subtree
- Groeperen per subtree
 - Kleuren
 - Namen
- Collapse behalve geselecteerde pad
- Zoekbalk in filtertab

Antwoorden onderzoeksvragen

Onderzoeksvraag 1

1. Welke basisfunctionaliteit is minimaal noodzakelijk om threat modeling met fortunately-unfortunately trees te ondersteunen?
 - Node-creatie
 - Uitklappen/inklappen
 - Zoeken

Onderzoeksvraag 2

2. Welke extra functies (bv. filters, zoekfuncties, statusiconen en visuele structuren) worden door gebruikers als het meest nuttig ervaren?
 1. Filtering op node-status
 2. Aantal nodes per status
 3. Classificering via het schild-icoon

Onderzoeksvraag 3

3. Hoe verhoudt de voorgestelde tool zich qua gebruiksvriendelijkheid en effectiviteit ten opzichte van een basisversie van mindmapsoftware?
- Betere gebruiksvriendelijkheid
 - Positieve UEQ-scores
 - Betere effectiviteit
 - Positieve UEQ-score
 - Vragen
 - Danger ratings
 - Status filter
 - Toegankelijker voor niet security-experts

Conclusie

Conclusie

- Threat modeling
 - Tijdsintensief
 - Security-experts
- Toegankelijkere aanpak
- Basisfunctionaliteiten
 - Werkt
 - Slechte efficiëntie
- Pragmatische UX-features → verbeterde efficiëntie
- Duidelijke verbetering uitgebreide versie
- Features toepassen in bestaande tools
- Verbeterde usability kan helpen bij security te verbeteren

Toekomstig werk

- Extra features testen
 - Branch zoom
 - Real-time samenwerken
 - AI-ondersteuning voor bv. threat-suggesties
- Verdere gebruikersstudie
 - Op grotere schaal
 - Langere periode
 - In “echte” werkomgeving

Vragen?

Vragen?

Gebruiksvriendelijke beveiligingsmodelleringtool voor de *fortunately-unfortunately* methode

Mika Gielkens

master IW Informatica

Introductie

Threat modeling is essentieel maar complex voor ontwikkelaars zonder securitykennis, waardoor *risicoanalyses* vaak onvolledig blijven [1]. Dit onderzoek ontwikkelt daarom een *gebruiksvriendelijke webtool* gebaseerd op de *fortunately-unfortunately methode*: een intuïtieve boomstructuur waarin dreigingen ("unfortunately", rood) afwisselen met tegenmaatregelen ("fortunately", groen). Het doel van dit onderzoek is een proof-of-concept tool ontwerpen, implementeren en evalueren die threat modeling *toegankelijker, overzichtelijker en effectiever* maakt voor niet experts.

Het onderzoek richt zich op drie kernvragen:

- Welke *minimale basisfunctionaliteit* is nodig om threat modeling met fortunately-unfortunately trees te ondersteunen?
- Welke *features* worden als *meest nuttig* ervaren?
- Hoe *verhoudt* de voorgestelde tool zich *qua gebruiksvriendelijkheid en effectiviteit* ten opzichte van *basisversie* van de mindmap software?

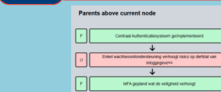
Methode

Op basis van *literatuurstudie* en *elisanalysen* werd een *React/JS webapplicatie* ontwikkeld met fortunately/unfortunately-boomfunctionaliteit en UX-features voor threat modeling. *Node-features* zoals *danger rating*, statusiconen en kleurcodering ondersteunen directe *node-interactie*:

- kleurcodering* (Fig. 1): (rood = unfortunately, groen = fortunately) met automatische afwisseling zorgt voor intuïtieve boomstructuur,
- statusiconen* (Fig. 2): tonen voortgang van een node aan de hand van Weakness (rood schild), Weakness Under Review (oranje schild), Assumption Under Review (oranje check schild), Verified Assumption (groen check schild) met hover-tooltips,
- danger rating* (Fig. 3): scoort unfortunately-nodes op basis van *likelihood* (1-5) × *impact* (1-5).

Overzicht-features verbeteren navigatie en contextbegrip:

- branch summary tab* (Fig. 4): toont het pad van root tot geselecteerde node voor contextueel overzicht,
- filter tab* (Fig. 5): groepeerde nodes per status (Weaknesses, Weakness Under Review, Assumptions Under Review, Verified Assumptions) met *danger rating-sortering* binnen de *weakness-categorieën* voor snelle navigatie en prioritering. Figuur 6 geeft de ingeklapte statussortering weer.



Figuur 4: Ingeklapte branch summary tab



Figuur 6: Ingeklapte filter tab met aantal nodes per status



Figuur 2: Uitgeklapte statusknoop



Figuur 1: Een fortunately-node (groen) en een unfortunately-node (rood)



Figuur 3: Uitgeklapte danger rating-knoop



Figuur 5: Uitgeklapte status filter met rangschikking op basis van danger rating

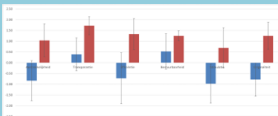
Resultaten

De *uitgebreide versie* van de fortunately-unfortunately tool leidt tot een *duidelijke betere gebruikerservaring* dan de basis mindmap-achtige versie. De *UEQ-resultaten* tonen een *verschuiving van overwegend negatieve naar positieve scores* op alle dimensies, met onder meer een hogere aantrekkelijkheid, efficiëntie (4,72 naar 1,33) en stimuleer voor de uitgebreide versie. Figuur 7 geeft de *score* (uitgebreide vs basis software, alle >0-postief) weer die werden verkregen uit de *user experience questionnaire* (UEQ).

In de observaties bleek dat deelnemers in de basisversie veel tijd verliezen met scrollen, zoeken en manueel tellen, terwijl *filters, statusiconen, danger rating en branch summaries* in de uitgebreide versie taken *merkbaar versnellen en minder foutgevoelig* maken.

Feature-ranking (1=meest nuttig, 8=minst):

- filtering op basis van node-status,
- tellen van nodes per status,
- classificering door het schild-icon.



Figuur 7: User experience questionnaire score

Conclusie

Een minimale mindmap-achtige ondersteuning volstaat om fortunately-unfortunately trees op te bouwen. Ze is echter onvoldoende voor vlotte, foutarme threat modeling door niet-security-experts. Door domeinspecifieke UX-features zoals *status-gebaseerde filtering, automatische danger rating, kleurcodering en branch summaries* daalt de *cognitieve belasting* voor gebruikers. De *uitgebreide tool* wordt consequent als *voorkeursversie* aangeduid en verschuift het *user-experience* (UX) profiel van negatief naar duidelijk positief, wat erop wijst dat gerichte UX-onverplekjes de *toegankelijkheid en adoptie* van threat modeling in DevSecOps-context *substantieel kunnen versterken*. Toekomstig werk richt zich op *AI-suggesties en online teamsamenwerking* voor bredere inzet in onderwijs- en industrie.

Promotoren / Copromotoren / Begeleiders

Prof. dr. ir. Koen Yskout, dr. Eva Geurts

[1] S. Vermeert, "Threat modeling in Nederlandse organisaties," 3 Oktober 2024. [Online]. Available: <https://cybersecurity-ibn.be/cybersecuritydesign/threat-modeling-in-nederlandse-organisatie-en/>. [Geraadpleegd 13 Oktober 2025]

De opleiding industriële ingenieur is een gezamenlijke opleiding van UHasselt en KU Leuven

UHASSELT

KU LEUVEN

Referenties